

Treinamento em Segurança Ofensiva 2024/2025

Relatório de Atividades	
Módulo 6:	Engenharia Social
Atividade 1:	Prática Engenharia Social
Nome:	Luiz Eduardo de Andrade

1. Introdução

Estas atividades fazem parte do módulo Engenharia Social, para a qual utilizaremos 2 técnicas com estratégias distintas de engenharia social que você utilizaria caso estivesse realizando um teste de engenharia social na Pacific.

No contexto deste módulo, nosso foco é:

- 1) Utilizar a Engenharia Social uma das formas mais fáceis de conseguir acesso a uma infraestrutura de uma empresa;
- 2) Conseguir a confiança dos funcionários da Pacific;
- 3) O telefone será utilizado para dar mais veracidade a estratégia de ser um funcionário de limpeza terceirizada.
- 4) Usar uniformes de uma empresa terceirizada para ter acesso físico a empresa;
- 5) Utilizar backdoor para ter acesso aos sistemas.

A tarefa de Engenharia Social é composta por duas atividades:

- 1) Ataque ao serviço terceirizado
- 2) Fingir ser do suporte técnico

2. Desenvolvimento

2.1. Configuração do ambiente

Os seguintes passos foram necessários para configurar o ambiente necessário para o desenvolvimento das atividades:

- 1) Fazer ligações telefônicas.

2) Utilizar pendrive com um backdoor

3) Utilizar uniformes da equipe de limpeza

O que é Engenharia Social?

Engenharia social é uma técnica que utiliza o fator humano com a persuasão, o objetivo é ganhar a confiança das pessoas, tentando convencer a passar informações pessoais, informações da empresa, clicar em links ou baixar anexos maliciosos, podendo assumir o controle dos sistemas da empresa ou da pessoa alvo.

Geralmente os engenheiros sociais se passam por funcionários de instituições ou com autoridade sobre o alvo ou também convencer que é uma pessoa que conhecida do alvo.

A engenharia social é perigosa porque não precisa que todos sejam enganados, apenas uma pessoa para desencadear um ataque potencialmente devastador, os ataques estão cada vez mais realistas sempre tentando convencer a vítima a fazer o que é solicitado.

Pode ser utilizada como método para primeiros ataques a empresa por ser simples, nem sempre necessitar de recursos tecnológicos, uma forma barata de conseguir os objetivos, utilizando do fator humano para enganar, da boa vontade das pessoas para conseguir acessos mais facilmente a dados ou sistemas empresariais.

Alguns dos tipos de ataques de engenharia social são, phishing, whaling, comprometimento do e-mail comercial, engenharia social física e isca USB.

Phishing é uma forma de enganar os usuários geralmente por e-mail que parece legítimo, tentando que seja fornecido informações confidenciais, clicar em links, baixar software malicioso, ransomware, além de links de empresas como a Microsoft, Netflix, Amazon informando que não fez o login corretamente ou que a sua conta precisa ser validada.

Whaling também conhecido como caça as baleias em português é uma técnica que você procura um executivo de alto valor na empresa, pesquisar sobre a vida dele nas redes sociais, na própria empresa, verificar LinkedIn, redes sociais e arquitetar um ataque muito bem elaborado onde contenha dados reais e que faça ele acreditar que o e-mail ou a abordagem é real e que consiga todos os objetivos.

Ataque de comprometimento de e-mail comercial o atacante se passa por um alto funcionário e tenta fazer com que o funcionário realize algum tipo de pagamento ou dar algum acesso.

Engenharia social física é a técnica de tentar entrar sem autorização do espaço físico

dentro da empresa para isso pode se utilizar de pretextos como se fosse entregar algum documento, entregar comida, entrar junto com os funcionários autorizados, para ter acesso as dependências da empresa, conseguir plugar um pen drive ou até entrar no datacenter destruir equipamentos importantes.

Isca USB é deixar um pen drive malicioso em lugares próximos a empresa com o intuito de alguém achar e plugar diretamente no computador da empresa baixando um malware, lembrando que mesmo que o pen drive seja formatado o malware continua nele.

2.2. Atividade prática

O objetivo desta atividade é utilizar 2 técnicas distintas de engenharia social

Atividade 1 – Ataque ao serviço terceirizado para ter acesso físico a empresa.

Passo 1 – A abordagem será me passar por um funcionário de limpeza que presta serviços para a Pacific.

Passo 2 – O que você diria ou faria em cada etapa da interação? Como a história será construída?
Como manter a credibilidade até alcançar o objetivo?

Na primeira etapa de interação eu verificaria qual empresa presta serviços conseguiria o nome da empresa, depois procuraria na internet os uniformes deles senão tivesse tentaria ir na hora do almoço para ver se saíam do prédio e eu pudesse fotografar e fazer uma roupa idêntica ou pelo menos muito parecida, o telefone da prestadora de serviço, ligaria para a Pacific autorizando a minha própria entrada, a história será construída onde irei fazer uma limpeza especial, ou vou em um dia que não há limpeza, a credibilidade será mantida pois vou ligar como responsável pela empresa autorizando eu entrar com o uniforme com esta autorização creio que não terei muitos problemas

Passo 3 – Objetivo específico da estratégia

Exemplo: Obter credenciais de e-mail para capturar arquivos confidenciais, instalar um keylogger para capturar credenciais e acessar documentos, etc.

Obs: Lembre-se da aula de modelagem.

Conseguir plugar um pen drive com backdoor em um dos computadores de preferência dos cargos mais altos para ter privilégios de administrador ou de alguém de TI, e conseguir acesso aos sistemas e até exfiltração de dados.

Passo 4 – Justificativa da escolha

Explique por que essa abordagem é adequada para o contexto da Pacific.

Esta abordagem é adequada pois não iria suspeitar de uma pessoa da limpeza.

2.3. Atividade 2 – Fingir ser do suporte para instalar na empresa um backdoor.

Passo 1 – Método utilizado

3

Como será feita a abordagem? Exemplo: se passar por um entregador, técnico terceirizado, analista do RH, ou realizar uma chamada fingindo ser de um setor interno.

Se passar por um suporte técnico do office 365 para ter acesso remoto ao computador

Passo 2 – Roteiro ou plano de ação detalhado

O que você diria ou faria em cada etapa da interação? Como a história será construída? Como manter a credibilidade até alcançar o objetivo?

Falo que sou da Microsoft e que há um problema com o Office 365 e que preciso de um acesso remoto para validar a conta, informo que pode haver um problema com o office 365 e preciso de acesso remoto para a conta, caso não tenha office 365 falo que preciso do acesso remoto para garantir que ele não está instalado e para a empresa não ser penalizada,

Passo 3 – Objetivo específico da estratégia

Exemplo: Obter credenciais de e-mail para capturar arquivos confidenciais, instalar um keylogger para capturar credenciais e acessar documentos, etc.

Obs: Lembre-se da aula de modelagem

Conseguir acesso remoto e instalar um APT (Advanced Persistent Threat – Ameaça Persistente Avançada) que é uma técnica em que o atacante consegue permanecer durante muito tempo em uma infraestrutura sem ser detectado, querem atingir os objetivos ou esperar o momento certo para atacar e conseguir o que mais desejarem, pode se exfiltrar informações por longo período, acessar documentos, este backdoor será utilizado sempre que for preciso.

Passo 4 – Justificativa da escolha

Explique por que essa abordagem é adequada para o contexto da Pacific.

Não irão desconfiar de um suporte técnico e podemos instalar o APT e ficar no sistema por um longo período, podemos roubar segredos comerciais, vazsar dados de clientes, verificar as vulnerabilidades dos clientes da pacif e utilizar estas vulnerabilidades para conseguir maiores ganhos, destruição da reputação da pacific,

2.4. Análise dos Resultados:

Foi realizada a execução da Engenharia Social.

Interpretação dos resultados:

- 1) Na Atividade 1 – Fazer uma invasão física, ou seja, entrar dentro da Pacific para conseguir colocar um pen drive em um dos computadores.
- 2) Na Atividade 2 – Nesta atividade fazer uma invasão tecnológica, através de um suporte técnico falso para instalar um APT.

3. Considerações finais

Nesta sala, exploramos técnicas de Engenharia Social, onde podemos explorar esta tática que utiliza o fator humano para conseguir os objetivos.

As principais lições aprendidas incluem:

- 1) Engenharia social é uma tática muito utilizada e muito eficaz que pode prejudicar muito uma empresa e ter consequências até mesmo irreversíveis.
- 2) Tomar cuidado com os colaboradores terceirizados.
- 3) Sempre que precisar acionar o TI para confirmar sobre tecnologia,

4. Referências

Site: <https://darknetdiaries.com/episode/90/>

Site: <https://darknetdiaries.com/episode/66/>

Site: <https://darknetdiaries.com/episode/40/>

Site: <https://darknetdiaries.com/episode/134/>

Site:

<https://www.cisco.com/c/en/us/products/security/what-is-social-engineering.html>

Site: <https://www.fortinet.com/resources/cyberglossary/advanced-persistent-threat>